# Case Study: SHIELD-AI Reference Implementation Assessment

**Sanitised field-validation record – August 2026.** This case study is the first Milestone 3 field-validation exercise: the SHIELD-AI assessment guide was run end-to-end against a real deployment of the framework's own reference implementation (`reference-impl/`). It validates the assessment methodology, produces honest maturity scores, and feeds findings back into the framework cycle.

## 1. Deployment context (sanitised)

The assessed deployment is the repository's reference implementation: two agent workloads (a billing assistant and a devops agent) running behind a Go sidecar gateway, evaluated against the full 59-control OPA policy set before every tool action, with a JSONL/SIEM audit pipeline. It is a reference deployment: it demonstrates the enforcement model with real code, real policies, and a continuously run verdict matrix, but it does not claim to be production infrastructure.

| Element | Detail |
|---|---|
| Enforcement model | Sidecar gateway evaluates every action deny-override against all 59 policies |
| Decision point | OPA server running the full `policies/` bundle |
| Telemetry | JSONL audit events per decision, forwarded to a SIEM sink |
| Verification | `make e2e` asserts a six-verdict matrix on every run; 253 OPA tests; 12 Go tests |
| Target maturity | L3 (agreed scoping for this exercise) |

## 2. Method

The guide's Section 8 methodology was applied as-is:

- **Phase 1 (pre-engagement):** artifact list compiled from the guide; regulatory scoping set to ISM/E8 + Privacy Act for a notional AU operator; target maturity L3.
- **Phase 2 (control assessment):** all 59 controls scored on the 1-5 evidence scale. Evidence was artifact-based and cross-validated: Rego implementations (`policies/`), OPA test vectors (253), the sidecar source (`reference-impl/sidecar/`), the e2e matrix and its output, and the configuration claims (`deployment.json`, `agents/`, `tools/`). Interview signals are not applicable to a self-assessment; artifact evidence carries the score.
- **Phase 3 (maturity scoring):** pillar maturity = lowest control score in the pillar; overall = lowest pillar. Evidence-to-maturity mapping: 1-2 = L1, 3 = L2, 4 = L3, 5 = L4.
- **Phase 4 (reporting):** findings, P0-P3 priorities, and a remediation roadmap below.

Evidence-score basis per control:

- **5** – the control's enforcement behaviour was observed in the e2e matrix (deny fired, or audit event emitted and asserted).
- **4** – the control is enforced by the sidecar's own attested mechanisms (gateway, audit pipeline, provenance, tenant scoping) on every decision, with unit tests.
- **3** – the control is enforced per decision through operator-asserted claims (agent config, deployment posture, tool registry), with unit tests.
- **2** – the control's posture is asserted in configuration but its action kind is never exercised by the reference deployment (training, deployment, evaluation, retrieval, MCP, code execution, publication, incident flows), or the enforcement point is caller-supplied.

# 3. Results

## 3.1 Pillar maturity

| Pillar | Lowest control | Maturity | Blocking controls |
|---|---|---|---|
| MS (Model Security) | MS-01 | L1 | MS-01/02/03/05/06/07/08/11 at evidence 2 |
| IAM (Identity and Access) | IAM-01 | L2 | IAM-01/02/04/05/06/07/08 at evidence 3 |
| DS (Data Security) | DS-01 | L1 | DS-01/02/04/05/06/07 at evidence 2 |
| TP (Tool and Pipeline Security) | TP-05 | L1 | TP-05/06/07/10/11 at evidence 2 |
| MIR (Monitoring and Incident Response) | MIR-04 | L1 | MIR-04 at evidence 2 |
| GRM (Governance and Risk Management) | GRM-04 | L1 | GRM-04 at evidence 2 |
| EE (Execution Environment) | EE-04 | L1 | EE-04/06/08 at evidence 2 |
| **Overall** | – | **L1** | weakest pillar (six pillars at L1) |

The weakest-link rule is doing its job: the deployment's genuine strengths (TP-01/02/09, EE-01/02, MS-04/09 at evidence 5) do not mask that most controls are configuration-asserted rather than operated. The reference implementation is L1 overall not because enforcement is weak where it exists, but because the framework's 59 controls span far more than the tool-call path the reference exercises.

## 3.2 Control evidence matrix

| Control | Evidence | Maturity | Basis |
|---|---|---|---|
| MS-01 Model weight protection | 2 | L1 | `key_management: hsm` asserted in deployment.json; no HSM artifact; model_deploy never exercised |
| MS-02 Training data integrity | 2 | L1 | training posture asserted; training_run never exercised |
| MS-03 Supply chain security | 2 | L1 | SBOM/signature claims asserted; model_deploy never exercised |
| MS-04 Adversarial robustness | 5 | L4 | deny observed in e2e (deny_injection, MS-04 marker) |
| MS-05 Model behaviour validation | 2 | L1 | guardrail claims caller-supplied; output_delivery never exercised |
| MS-06 Model inventory and lineage | 2 | L1 | inventory claims asserted; model_deploy never exercised |
| MS-07 Deployment context obfuscation | 2 | L1 | evaluation claims asserted; evaluation_run never exercised |
| MS-08 MCP security | 2 | L1 | MCP claims asserted; mcp_connect never exercised |
| MS-09 Perception-fidelity approvals | 5 | L4 | deny observed in e2e (deny_injection, MS-09 fidelity snapshot) |
| MS-10 Agent memory-store integrity | 3 | L2 | memory write_auth/tamper claims enforced per tool_call |
|  | 2 | L1 | trigger=log_alert path never exercised; policy + tests exist |

| Control | Evidence | Maturity | Basis |
|---|---|---|---|
| MS-11 Operational data-stream integrity | | | |
| IAM-01 Agent identity management | 3 | L2 | agents/*.json identity claims enforced per call; config-file identities, not SPIFFE |
| IAM-02 Scope-bound delegation | 3 | L2 | delegation scoped/wildcard claims enforced per call |
| IAM-03 Human oversight | 4 | L3 | approval gating enforced at runtime (financial transfer requires human-console approval); channel binding caller-asserted |
| IAM-04 Credential isolation | 3 | L2 | credential claims enforced per call |
| IAM-05 Just-in-time access | 3 | L2 | ephemeral/revocation claims enforced per call |
| IAM-06 Cross-session boundary | 3 | L2 | session independence claims enforced per call |
| IAM-07 Delegation chain enforcement | 3 | L2 | hops/max_hops claims enforced per call |
| IAM-08 Credential scope narrowing | 3 | L2 | per-tool scope claims enforced per call |
| IAM-09 Multi-tenant isolation | 4 | L3 | tenant scoping sidecar-attested from agent config at the data layer |
| DS-01 Data classification | 2 | L1 | classification claims asserted; ingestion never exercised |
| DS-02 Inference data protection | 2 | L1 | TLS/e2e claims asserted; no transport enforcement in reference |

| Control | Evidence | Maturity | Basis |
|---|---|---|---|
| DS-03 Memory sanitisation | 3 | L2 | memory persistence claims enforced per tool_call |
| DS-04 Data minimisation | 2 | L1 | retrieval minimisation asserted; retrieval never exercised |
| DS-05 Training data governance | 2 | L1 | governance claims asserted; training_run never exercised |
| DS-06 Output validation | 2 | L1 | output_scan is caller-supplied; no gateway-side scan in reference |
| DS-07 Artifact publication control | 2 | L1 | publication kind never exercised; policy + tests exist |
| TP-01 Tool inventory and registry | 5 | L4 | deny observed in e2e (deny_unregistered_tool) |
| TP-02 Tool access control | 5 | L4 | deny observed in e2e (tool_allowed false) |
| TP-03 API gateway security | 4 | L3 | gateway claims sidecar-attested per call (rate limit, schema, audit) |
| TP-04 Tool output validation | 4 | L3 | tool_output claims sidecar-attested; schema validation implemented |
| TP-05 Pipeline integrity | 2 | L1 | pipeline claims asserted; deployment never exercised |
| TP-06 Dependency scanning | 2 | L1 | dependency claims asserted; deployment never exercised |
| TP-07 Cross-tool dependency analysis | 2 | L1 | tool-chain claims asserted; deployment never exercised |
| TP-08 Gateway infra-isolation | 4 | L3 | |

| Control | Evidence | Maturity | Basis |
|---|---|---|---|
| | | | gateway infra-isolation sidecar-attested; infra API deny path present |
| TP-09 Explicit tool registration | 5 | L4 | deny observed in e2e (registration claim) |
| TP-10 Inbound control-plane protection | 2 | L1 | binding kind never exercised; policy + tests exist |
| TP-11 Browser/ content isolation | 2 | L1 | cross_origin/ document_render kinds never exercised |
| TP-12 Tool-call provenance | 4 | L3 | provenance sidecar-minted per call; approved transfer passes the full set |
| MIR-01 Agent activity logging | 5 | L4 | audit emission asserted in e2e (deny audits + SIEM events counted) |
| MIR-02 Behavioural anomaly detection | 3 | L2 | anomaly/swarm policy enforced per call; no detection backend in reference |
| MIR-03 Prompt audit log | 4 | L3 | sensitive prompt capture/ redaction sidecar-attested per call |
| MIR-04 Incident response playbooks | 2 | L1 | no playbook artifacts in reference; policy + tests exist |
| MIR-05 Mandatory reporting integration | 3 | L2 | reporting trigger sidecar-attested when incident flagged; not exercised |
| MIR-06 Forensic readiness | 4 | L3 | reconstructible claims sidecar-attested; append-only JSONL store |
| | 3 | L2 | |

| Control | Evidence | Maturity | Basis |
|---|---|---|---|
| GRM-01 AI governance body | | | governance body claims in deployment.json, applied per decision |
| GRM-02 AI risk register | 3 | L2 | register + kill-switch claims; no actual register artifact |
| GRM-03 Ethical use policy | 3 | L2 | acceptable-use claims applied per decision |
| GRM-04 Third-party AI risk management | 2 | L1 | no vendor configuration in reference; vendor path never exercised |
| GRM-05 Regulatory mapping | 3 | L2 | compliance mapping claims applied per decision |
| GRM-06 Board and executive reporting | 3 | L2 | dashboard claims; no actual dashboard artifact |
| EE-01 Execution boundary enforcement | 5 | L4 | deny observed in e2e (deny_unsandboxed_highrisk) |
| EE-02 Infrastructure API access control | 5 | L4 | deny observed in e2e (deny_infra_api) |
| EE-03 Resource usage limiting | 3 | L2 | resource limits in agent config, enforced per call |
| EE-04 Evaluation sandbox integrity | 2 | L1 | harness claims asserted; evaluation_run never exercised |
| EE-05 Host-trusted file injection | 3 | L2 | host-trusted path detection + fail-closed allowlist; config-schema drift found and fixed in the coverage expansion (see F11) |
| EE-06 Fail-closed sandbox operation | 2 | L1 | code_execution kind never exercised; policy + tests exist |

| Control | Evidence | Maturity | Basis |
|---|---|---|---|
| EE-07 Control-plane configuration integrity | 3 | L2 | control-plane write gating live for file_write flows after the config fix (see F11) |
| EE-08 Evaluation-harness isolation | 2 | L1 | harness claims asserted; evaluation_run never exercised |

## 4. Findings and priorities

| ID | Priority | Finding | Evidence |
|---|---|---|---|
| F1 | P1 | No incident-response playbooks ship with the reference deployment; MIR-04 coverage is claimed by policy only | `reference-impl/` has no playbook artifacts |
| F2 | P1 | DS-06 output validation is caller-supplied; the gateway does not own the output scan, so leakage scanning is not enforced at the boundary | enrichment leaves `output_scan` untouched |
| F3 | P1 | The e2e matrix exercises 12 of 59 controls at runtime; 47 controls are evaluated but never deny-observed, so “continuously verified” claims cover only the exercised subset | e2e matrix + this assessment |
| F4 | P2 | Posture in deployment.json (MS-01/02/03, DS-01/02, TP-05/06/07, GRM-01..06) is asserted, not operated; no operational evidence exists for HSM, registry, pipeline, or governance claims | deployment.json vs repository state |
| F5 | P2 | TP-12 provenance is sidecar-minted ( `model_sig: sidecar-` | sidecar/enrich.go |

| ID | Priority | Finding | Evidence |
|---|---|---|---|
| | | `minted`); the production model-turn signature requirement is substituted | |
| F6 | P2 | The sidecar self-attests its own gateway and audit claims; no independent verification of the enforcement boundary exists | sidecar/enrich.go attestation block |
| F7 | P2 | IAM-01 uses config-file identities; production requires SPIFFE/SPIRE workload identities | agents/*.json |
| F8 | P3 | No TLS between sidecar and OPA; production topology requires mTLS on the decision path | docker-compose.yml, sidecar config |
| F9 | P3 | agent-billing allowlist includes transfer_funds and write_file; demo least-privilege posture is broad by design | agents/agent-billing.json |
| F10 | P3 | Tenant scoping is demonstrated but only one tenant is configured; no cross-tenant test exists | agents/ tenant_id config |
| F11 | P1 | **Config-schema drift (found and fixed by the F3 coverage expansion, Aug 2026):** agent configs declared `path_writable` at the agent root, but EE-05/EE-07 evaluate `agent.config.path_writable` (the canonical input model in `policies/README.md`). The control-plane write-gating branch of EE-07 was therefore dead in the reference deployment, and EE-05's host-trusted detection could never fire | EE-05/EE-07 regos vs agents/*.json; caught when the expansion tried to deny-observe EE-07 |

## 4.1 Follow-up: F3 coverage expansion (August 2026)

Immediately after this assessment, the F3 finding was actioned: the e2e matrix was expanded from 6 to 28 cases covering every action kind the policy set can gate (tool_call, code_execution, file_write, memory_write, retrieval, output_delivery, publication, mcp_connect, binding, document_render, evaluation_run, model_deploy, training_run, ingestion, deployment, session_end, log-alert triggers, incident flow).

- **47 of 59 controls now deny-observed at runtime**, each with its deny message asserted case by case (no marker, no pass).
- The remaining 12 are positively exercised: their claims are satisfied and evaluated on real requests (MIR-01/03/06 telemetry and attestation, TP-04/08 gateway claims, TP-12 provenance, IAM-09 tenant scoping, GRM-01/02/05/06 governance posture). **All 59 controls are exercised at runtime on every request.**
- Telemetry assertions are now computed from the matrix (26 deny audits, 28 SIEM exports), so under-reporting fails the run.
- The expansion caught a real bug (F11): the `path_writable` config-schema drift that had silently disabled EE-07's control-plane branch and EE-05's host-trusted detection in the reference deployment. Both agent configs were corrected to the canonical input model, and the e2e now asserts EE-05/EE-07 deny markers so the drift cannot return unnoticed.

F3 is **resolved**: the exercised-control gap is closed, and the coverage map for the matrix is the marker list in `reference-impl/scripts/e2e.sh` itself.

# 5. Remediation roadmap

Sequence by critical path, then risk. Item 1 completed by the follow-up above (F3 resolved, August 2026):

1. **Close the exercised-control gap (F3).** Extend the e2e matrix with deny-observation cases for code_execution (EE-06), retrieval (DS-04), output_delivery (DS-06/MS-05), binding (TP-10), mcp_connect (MS-08), log-alert triggers (MS-11), deployment (TP-05/06/07), and evaluation_run (EE-04/08, MS-07). Target: runtime observation of at least half the controls.

2. **Ship playbooks (F1).** Add MIR-04 playbook artifacts (prompt injection, model compromise, tool abuse, code-generation) to the reference deployment.
3. **Move DS-06 into the gateway (F2).** Add an output-scan endpoint the sidecar calls before delivery, making the scan a sidecar-attested claim like TP-04.
4. **Replace substitution mechanisms with documented gates (F5, F6, F7).** Gate sidecar-minted provenance, self-attested claims, and config-file identities behind explicit production-readiness markers.
5. **Operational evidence for asserted posture (F4).** Where claims cannot be independently evidenced in a reference deployment, scope them out of coverage rather than scoring them at face value.
6. **Transport hardening (F8).** Add TLS/mTLS to the sidecar and decision path when the deployment topology is exercised.

## 6. Lessons fed back to the framework

Recorded in full in `framework/shield-ai-field-findings.md`. Summary:

- **The configuration-assertion trap.** A deployment can assert any posture in a config file; the guide's artifact lists should require operational evidence (logs, attestations, exercised runs), not configuration claims.
- **Weakest-link scoring conflates "not assessed" with "L1".** The scoring guide should add an explicit "not exercised" evidence state so a reference or partial deployment is not penalised identically to a failing one.
- **Validation suites need a coverage map.** The framework should define a minimum exercised-control ratio before a deployment may claim "continuously verified" enforcement.
- **Positive controls belong in the method.** The allow_approved_transfer case (a high-risk action passing all 59 controls) proved the full-set evaluation path; the guide's Phase 2 should require a positive control per engagement.
- **Substitution disclosure.** Reference implementations that substitute framework mechanisms (minted provenance, config-file identity) should declare the substitution; the guide gains a disclosure requirement.
- **Self-attestation is a first-party GRM-04 lesson.** The requirement for independent verification of isolation/egress claims applies to first-party components too, not just third-party vendors.

## 7. Sanitisation note

This record names no client, contains no credentials, and publishes only the repository’s own artefacts as evidence. It is suitable for sharing with prospects as evidence that the framework’s assessment method is executable against real deployments.